

Watch your service — find the attack in the logs

Session 9 – Security monitoring & IDS

Exercise 9 · Session 9 lab · Estimated time: 90–120 min

Write your answers in the answer document `SKY2100_Exercise9_Answers.docx`. Your Nextcloud is encrypted (S6), hardened (S7) and shielded by a WAF (S8). Those controls already produce telemetry. Today you collect it in one place, then hunt for the attacks you blocked last week and a brute-force pattern – the difference between blocking an attack and seeing it.

Caution: Monitor and generate traffic only on your own VM. The “attacks” below are harmless probes against your own service.

1 Collect the logs in one place

▷ Identify and gather the security-relevant logs your VM already produces:

```
sudo tail -n 20 /var/log/auth.log
sudo fail2ban-client status sshd
sudo tail -n 20 /var/log/modsec_audit.log          # WAF (path may differ)
sudo journalctl -u nginx -no-pager | tail -n 20
```

Note: No `/var/log/auth.log`? Ubuntu without `rsyslog` keeps these lines in the journal: `sudo journalctl -u ssh -no-pager | tail -n 20`, and in Section 3 use `sudo journalctl -u ssh | grep "Failed password"` instead of the `grep` on the file.

▷ Which log would you check first if you suspected (a) a brute-force login, (b) a blocked web attack, (c) a service crash? One line.

2 Find last week’s attack in the WAF log

▷ Re-send one of your S8 test payloads, then locate it in the ModSecurity audit log:

```
curl -k "https://<your-host>/?q=<script>alert(1)</script>"
sudo grep -iE "alert\(1\)|XSS|941" /var/log/modsec_audit.log | tail
```

▷ Which CRS rule fired (rule ID / message), what was the source IP, and what status was returned?

3 Spot a pattern — brute force over time

▷ Generate a few failed SSH logins (from another host or with a wrong key/user), then look for the pattern, not the single line:

```
sudo grep "Failed password" /var/log/auth.log | tail -n 20
sudo grep "Failed password" /var/log/auth.log | wc -l
sudo fail2ban-client status sshd
```

▷ How many failures, from how many distinct IPs, over what time window? Why is the pattern the alert, not any single failed login?

AHA. You blocked these attacks weeks ago, so why look at them now? Because blocking and seeing are different things. fail2ban and the WAF stopped the attempts, but only the logs tell you they happened at all, who tried, and how often. Notice too what counts as the signal. A single failed login is nothing; people mistype passwords all the time. The alert is the pattern, many failures from one or a few addresses in a short window, which no single line reveals. This is exactly why logs have to be collected in one place and read together, and it is the groundwork for the timeline you build next week.

4 (Optional) Run an IDS — Suricata

▷ Install Suricata, run it on your interface, and read one alert:

```
sudo apt install -y suricata
sudo suricata -i <iface> &
sudo tail -f /var/log/suricata/fast.log
```

▷ Is Suricata here a NIDS or a HIDS, and is it signature- or anomaly-based by default? One line.

5 Cloud transfer: Microsoft Learn

▷ Work through “Introduction to Microsoft Sentinel” and note what a cloud-native SIEM does.

learn.microsoft.com/training/modules/intro-to-azure-sentinel

▷ Name the three things a SIEM does with telemetry (hint: collect, . . . , . . .), and one advantage of a SIEM over reading each host’s logs by hand.

6 Azure reflection

▷ CSA distinguishes logs (slow path) from events (fast path). For detecting a fast-moving management-plane attack, which would you rely on, and why?

▷ Your fail2ban and WAF blocked attacks. Why is also logging and alerting on them valuable, even though they were already stopped?

7 Knowledge check

1. Why is “assume breach” the starting point for monitoring?

Hint: Prevention is never perfect — plan to catch what gets through.

2. State the difference between a **log** and an **event** (CSA).

Hint: One is the full, durable record; one is a single notable occurrence.

3. State the difference between an **event** and an **alert**.

Hint: Raw captured data, versus an actionable notification derived from it.

4. Name three telemetry sources you would collect on a VM.

Hint: auth.log, fail2ban, the WAF audit log, the web access log — any three.

5. Why must logs be centralised and protected?

Hint: Scattered logs cannot be correlated; local ones an attacker can edit.

6. Signature vs anomaly detection: one strength and one weakness of each.

Hint: One is precise but blind to new attacks; one catches new ones but is noisy.

7. Difference between **NIDS** and **HIDS**, with one example tool each.

Hint: One watches network traffic; one watches a single host’s logs and files.

8. Difference between an **IDS** and an **IPS**.

Hint: One alerts, one blocks — a WAF is the blocking kind for HTTP.

9. What is a **SIEM**, and what does “correlation” add?

Hint: It aggregates many sources; correlation ties separate events into one story.

10. What does the **MITRE ATT&CK** framework provide?

Hint: A map of real attacker tactics — context for which indicator means what.

11. Define **MTTD** and why it matters.

Hint: Mean time to detect — the longer the dwell time, the worse the damage.

12. What is **alert fatigue**, and how is it reduced?

Hint: Too many low-value alerts hide the real one; prioritise and tune.

Progress check: Discuss your answers in the group, then talk the teacher through them verbally at the next session only to track progress; nothing is handed in, signed or graded.

Solutions

Work through the lab first, then check here. Model answers are indicative — equivalent reasoning is fine.

Note: Model answers are indicative – accept equivalent reasoning. Multiple-choice answers are in **bold**.

Knowledge check

1. Prevention (firewall, TLS, hardening, WAF) is never perfect – new vulnerabilities, stolen credentials and novel payloads slip through. “Assume breach” means you also build detection to catch what gets in, rather than trusting that nothing will.
2. A **log** is a relatively complete, detailed, durable record of activity (CRUD), often batched and slightly delayed. An **event** records only a change (C-UD), is ephemeral (not kept unless saved) and is available within seconds (CSA p. 125).
3. An **event** is raw captured data/activity; an **alert** is an actionable notification derived from analysing events, signalling a potential threat. Events are the input; alerts are the output worth acting on (CSA p. 124).
4. Any three of: `/var/log/auth.log` (logins/sudo), fail2ban log (bans), the WAF/ModSecurity audit log (blocked attacks), the web access log (requests/status), `journalctl/syslog` (service & system events). (CSA management-plane / service / resource logs, p. 128.)
5. **Centralised:** scattered logs cannot be correlated and give no overview of the whole estate (CSA p. 125). **Protected:** an attacker who can edit/delete logs erases their trail (the C-UD evasion, CSA p. 137); ship logs off-host, append-only.
6. **Signature:** precise, low false positives, but blind to novel attacks. **Anomaly:** can catch unknown attacks by learning “normal”, but more false positives and needs tuning (CSA p. 126).
7. **NIDS** inspects network traffic (e.g. Suricata, Snort); **HIDS** watches one host’s logs, files and processes (e.g. Wazuh, OSSEC). NIDS sees the knock; HIDS sees what happens inside.
8. An **IDS** detects and alerts; an **IPS** detects and blocks. The WAF is an application-layer IPS.
9. A **SIEM** aggregates, analyses and correlates logs/events from many sources (CSA p. 138). **Correlation** ties separate events (failed login + config change + data export) into one meaningful incident no single log would reveal.
10. **MITRE ATT&CK** maps real attacker tactics and techniques, giving context for which indicators relate to which attack stage, so teams focus on the attacks most relevant to them (CSA p. 126).
11. **MTTD** = mean time to detect: the gap between an attack starting and being noticed. It matters because the longer the dwell time, the more an attacker learns, spreads and exfiltrates.
12. **Alert fatigue:** too many low-value alerts cause analysts to miss the real one. Reduced by prioritising (severity/confidence), tuning out false positives, and correlating many events into fewer incidents (CSA p. 124).

Lab checkpoints

- **Collect:** students should locate at least `auth.log`, the fail2ban status, the WAF audit log and the web/access log. First-check mapping: brute force → `auth.log`/fail2ban; blocked web attack → WAF audit log; crash → `journalctl/syslog`.
- **WAF log:** the re-sent XSS probe should appear with a CRS rule (typically a 941xxx XSS rule), the source IP and a 403. This is the “see what you blocked” moment – blocking and logging are different jobs.
- **Brute-force pattern:** several **Failed password** lines from one or more IPs in a short window.

The teaching point (CSA p. 137): one failure is noise; “repeated login attempts from different IPs” over time is the alert-worthy pattern.

- **Suricata (optional):** by default a **NIDS, signature-based** (rule sets). A single `fast.log` alert (e.g. a scan or a rule hit) is enough.

Cloud transfer & reflection

- **SIEM:** collects, correlates and alerts on telemetry from many sources. Advantage over per-host logs: one place to search, cross-source correlation, and consistent alerting – you see the whole estate, not one machine.
- **Logs vs events for a fast attack:** rely on **events** (the fast path, near-real-time, e.g. Defender/GuardDuty/Sentinel) for management-plane attacks, because logs are the slow path and delays are unacceptable when attacks move fast (CSA p. 126, 137).
- **Why log blocked attacks:** blocking stops this attempt; logging/alerting reveals that you are being targeted, by whom and how often, feeds correlation and forensics, and meets compliance – detection and prevention are complementary, not redundant.

References

CSA Security Guidance v5, **Domain 6: Security Monitoring** (p. 124–143, verified): cloud monitoring challenges and management plane (p. 125–126), logs vs events and their uses (p. 125–126), events vs alerts (p. 124), timeliness and key indicators / MITRE ATT&CK (p. 126), telemetry sources (p. 127–128), detection paths and the C-UD evasion example (p. 137), SIEM vs CSP alerts vs CSPM (p. 138). Comer, *The Cloud Computing Book*, Ch. 17.8 – AI & security analytics: context-aware anomaly detection and DDoS detection (p. 239), verified. MS Learn: Introduction to Microsoft Sentinel (verified, June 2026) – cloud-native SIEM + SOAR.